SECURITY ONION ET DÉTECTION DES CYBERATTAQUES RÉSEAU

BTS SIO — Option SISR | Dossier de veille technologique | Période étudiée : 2025–2026

Problématique : Comment Security Onion aide-t-il les entreprises à détecter et analyser les cybermenaces, afin de limiter les conséquences des attaques et de renforcer la sécurité de leurs infrastructures réseau ?

1. QU'EST-CE QUE LA VEILLE TECHNOLOGIQUE ?

La veille technologique est une démarche continue de recherche, de collecte, de vérification et d'analyse d'informations sur les innovations et les évolutions techniques d'un domaine. Elle permet d'anticiper les changements, de mettre à jour ses connaissances et d'évaluer les conséquences possibles sur une organisation.

Dans le domaine des réseaux et de la cybersécurité, elle consiste notamment à suivre les mises à jour logicielles, les nouvelles vulnérabilités, les méthodes d'attaque, les outils de détection et les recommandations des organismes spécialisés.

2. PRÉSENTATION DU THÈME : SECURITY ONION

Security Onion est une plateforme de surveillance de la sécurité informatique, utilisée pour la détection d'intrusions, la visibilité réseau et l'investigation d'incidents. Elle rassemble plusieurs outils de collecte et d'analyse afin d'aider un analyste à comprendre ce qui se passe sur un réseau ou sur des systèmes supervisés.

Dans un réseau d'entreprise, une sonde Security Onion peut recevoir une copie du trafic grâce à un port miroir (SPAN) sur un commutateur ou à un TAP réseau. Elle analyse alors les paquets sans devoir se placer directement sur le chemin des communications. Des journaux provenant des postes et serveurs peuvent également enrichir l'analyse, selon la configuration.

Security Onion est principalement une solution de détection et d'investigation : il ne faut pas la présenter comme un pare-feu bloquant automatiquement toutes les attaques.

3. POURQUOI CE SUJET ?

Pour un technicien ou administrateur SISR, comprendre les réseaux ne suffit pas : il faut également savoir repérer les comportements suspects, interpréter les journaux et participer à la réponse aux incidents. Security Onion permet de relier des compétences de réseau (TCP/IP, VLAN, DNS, ports, commutation) à des compétences de cybersécurité (IDS, analyse de logs, investigation et gestion d'alertes).

4. LES ENJEUX POUR LES ENTREPRISES

Confidentialité : empêcher l'accès non autorisé aux informations sensibles, aux comptes et aux données clients.

Intégrité : détecter les modifications anormales de fichiers, de configurations ou de communications.

Disponibilité : limiter l'impact des incidents sur les serveurs, les applications et les services métier.

Visibilité : savoir quelles machines communiquent, avec qui et par quels protocoles.

Réactivité : détecter tôt une activité suspecte et transmettre des informations exploitables à l'équipe informatique.

Conformité et traçabilité : conserver des traces utiles à l'analyse des incidents, selon les obligations applicables.

5. CONSÉQUENCES POSSIBLES DES CYBERATTAQUES

Conséquence	Exemple concret
Vol de données	Exfiltration de fichiers clients ou d'identifiants depuis un serveur compromis.
Interruption de service	Rançongiciel paralysant des postes et empêchant l'accès aux applications.
Pertes financières	Coûts de restauration, d'expertise et arrêt temporaire d'activité.
Atteinte à la réputation	Perte de confiance des utilisateurs ou des partenaires.
Propagation interne	Déplacement latéral d'un attaquant vers d'autres machines du réseau.

Une détection rapide peut réduire le délai d'investigation et faciliter la réaction. Elle ne garantit cependant pas l'absence de dommages : la prévention, les sauvegardes, la segmentation et la gestion des correctifs restent indispensables.

6. LES OUTILS ET TECHNOLOGIES INTÉGRÉS

Composant	Rôle	Exemple d'utilisation
Suricata	Moteur NIDS utilisant notamment des règles de détection.	Déclencher une alerte sur une signature de trafic malveillant.
Zeek	Analyse les protocoles et produit des journaux structurés.	Étudier des connexions, requêtes DNS ou échanges HTTP.
Security Onion Console (SOC)	Interface centralisée pour les alertes, la recherche et l'investigation.	Consulter une alerte et examiner les événements associés.
Captures PCAP	Enregistrement de paquets réseau, selon la configuration.	Reconstituer un échange suspect paquet par paquet.
Collecte de journaux	Récupération d'événements de systèmes et d'équipements compatibles.	Corréler une activité réseau avec des événements d'un serveur.

7. FONCTIONNEMENT : DU TRAFIC RÉSEAU À L'ALERTE

1. Un poste du réseau échange des données avec un serveur ou Internet.

2. Le commutateur transmet une copie du trafic vers l'interface de capture de la sonde (SPAN/TAP).

3. Suricata compare certains éléments du trafic à ses règles ; Zeek extrait des métadonnées et journaux de protocoles.

4. Les événements sont collectés, indexés et consultables dans les interfaces prévues.

5. L'analyste examine l'alerte, les journaux et, si disponible, la capture PCAP.

6. L'équipe informatique décide des mesures : isolation d'un poste, blocage sur le pare-feu, changement de mot de passe, correctif ou enquête complémentaire.

8. EXEMPLE PRATIQUE : TENTATIVE DE SCAN DE PORTS

Scénario pédagogique : dans un laboratoire autorisé, une machine effectue un scan de ports vers un serveur de test. La sonde voit passer les paquets grâce au port miroir. Les journaux Zeek permettent d'observer de nombreuses tentatives de connexion vers différents ports ; une règle Suricata adaptée peut également générer une alerte. L'analyste vérifie les adresses IP, l'heure, les ports visés et le contexte pour déterminer s'il s'agit d'un test légitime ou d'un comportement suspect.

9. AUTRES APPLICATIONS CONCRÈTES

Recherche de communications inhabituelles vers des adresses IP externes.

Analyse d'activités DNS anormales, comme des requêtes répétées vers des domaines suspects.

Investigation d'une alerte Suricata en recoupant les journaux Zeek et les paquets capturés.

Analyse des connexions entre VLAN ou sous-réseaux lorsque la sonde a accès à ce trafic.

Appui à la réponse aux incidents : identification des machines et périodes à examiner.

10. LIMITES ET PRÉCAUTIONS

La sonde ne peut analyser que le trafic qui lui est effectivement transmis.

Le trafic chiffré limite l'inspection du contenu ; certaines métadonnées restent observables.

Les signatures peuvent produire des faux positifs et ne détectent pas toutes les attaques inconnues.

Le stockage des journaux et des PCAP peut nécessiter des ressources importantes.

Une équipe doit interpréter les alertes et décider des actions : la détection seule ne bloque pas automatiquement l'attaque.

La collecte doit respecter les règles de confidentialité et les politiques de l'organisation.

11. MÉTHODOLOGIE DE VEILLE : PUSH ET PULL

Méthode Push

La méthode Push consiste à recevoir automatiquement les informations : flux RSS du blog officiel, alertes par mots-clés, abonnements à des bulletins de sécurité ou notifications de nouvelles versions. Exemples de mots-clés : « Security Onion release », « Suricata update », « Zeek security », « network intrusion detection ».

Méthode Pull

La méthode Pull consiste à rechercher volontairement des informations : consulter la documentation et les annonces officielles, comparer les notes de versions, rechercher des CVE pertinentes et vérifier les analyses techniques publiées par des sources fiables.

Méthode de sélection des informations

Pour chaque actualité retenue : relever la date de publication, l'auteur, le lien, la version concernée, la nouveauté, les impacts techniques et l'intérêt pour une infrastructure d'entreprise. Vérifier les informations importantes dans une source primaire avant de les utiliser.

12. SUIVI DES ÉVOLUTIONS 2024–2026

Le suivi doit privilégier des informations datées et vérifiables : versions de Security Onion, nouveautés de Security Onion Console, évolutions de Suricata et Zeek, correctifs de sécurité et changements de compatibilité. Le tableau ci-dessous sert de support de veille : les entrées sont à renseigner à partir d'articles réellement consultés, et non de dates supposées.

Date	Source / article	Évolution technique	Impact / analyse
	Annonce officielle Security Onion	Version ou fonctionnalité documentée	Conséquences pour la surveillance réseau
	Notes de version Suricata	Nouvelles capacités ou correctifs	Intérêt pour la détection
	Notes de version Zeek	Améliorations des journaux ou protocoles	Intérêt pour l'investigation

13. ÉVÉNEMENTS ET ACTIVITÉS PROFESSIONNELLES

CTF (Capture The Flag) : exercices pratiques de cybersécurité pour progresser en analyse réseau, journaux et investigation.

SSTIC : conférence française consacrée à la sécurité des technologies de l'information et des communications.

SuriCon : événement de la communauté Suricata, utile pour suivre les évolutions du moteur de détection.

Conférences et ateliers de sécurité réseau : retours d'expérience sur la supervision, les IDS et la réponse aux incidents.

15. SOURCES RECOMMANDÉES

Documentation officielle Security Onion — https://docs.securityonion.net/

Site officiel Security Onion — https://securityonion.net/

Blog officiel Security Onion — https://blog.securityonion.net/

Suricata — https://suricata.io/

Documentation Zeek — https://docs.zeek.org/

CERT-FR / ANSSI — https://www.cert.ssi.gouv.fr/

MITRE ATT&CK — https://attack.mitre.org/

SSTIC — https://www.sstic.org/

SuriCon — https://www.suricon.net/